

Security+ 5.4 · Compliance

Mestre CyberSec — PDF baseado na aula do Professor Messer · 5.4 — Compliance (8:06) · [vídeo original ↗](#) · [YouTube ↗](#)

Compliance: seguir a LEI + NORMA (PCI-DSS, HIPAA, GDPR, SOX/LGPD) do setor e região; reputational damage (perde cliente mesmo sem multa); monitoring (verificar, NÃO só na auditoria anual).

Highlights que a prova cobra

- Compliance: leis do setor + região (GDPR/PCI/HIPAA)
- Reputational damage costuma custar MAIS que a multa

Dicas de prova

- 'protecting cardholder data'=PCI-DSS compliance

Cenário clássico: 'processadora de cartão precisa seguir'=PCI-DSS.

Perguntas de treino (10 questões)

Gabarito no fim. Tenta responder SEM olhar.

1. Qual lei regula a proteção de dados pessoais na União Europeia?

- A) HIPAA
- B) GLBA
- C) GDPR
- D) SOX

2. HIPAA (Health Insurance Portability and Accountability Act) protege informações relacionadas a:

- A)** Dados financeiros
- B)** Dados educacionais
- C)** Informações de saúde protegidas (PHI)
- D)** Informações de defesa nacional

3. HIPAA, GLBA e GDPR protegem, respectivamente, dados de:

- A)** Saúde (US) / Financeiro (US) / Pessoais (UE)
- B)** Governo / Militar / Escolar
- C)** Cartão / Senha / Biometria
- D)** Nuvem / Rede / Endpoint

4. Cenário corporativo (Compliance): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.4), um analista avalia o seguinte requisito técnico: 'Compliance: leis do setor + região (GDPR/PCI/HIPAA)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Compliance: leis do setor + região (GDPR/PCI/HIPAA)...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Compliance): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.4), um analista avalia o seguinte requisito técnico: 'Reputational damage costuma custar MAIS que a multa'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Reputational damage costuma custar MAIS que a multa...

6. Cenário corporativo (Compliance): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.4), um analista avalia o seguinte requisito técnico: "protecting cardholder data'=PCI-DSS compliance'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'protecting cardholder data'=PCI-DSS compliance...

7. Cenário corporativo (Compliance): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.4), um analista avalia o seguinte requisito técnico: "processadora de cartão precisa seguir'=PCI-DSS.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'processadora de cartão precisa seguir'=PCI-DSS....
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Compliance): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.4), um analista avalia o seguinte requisito técnico: 'Compliance: leis do setor + região (GDPR/PCI/HIPAA)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Compliance: leis do setor + região (GDPR/PCI/HIPAA)...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Compliance): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.4), um analista avalia o seguinte requisito técnico: 'Reputational damage costuma custar MAIS que a multa'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Reputational damage costuma custar MAIS que a multa...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Compliance): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.4), um analista avalia o seguinte requisito técnico: 'protecting cardholder data'=PCI-DSS compliance'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'protecting cardholder data'=PCI-DSS compliance...

GABARITO COMENTADO

- 1) C — GDPR.** GDPR (General Data Protection Regulation) é a regulamentação europeia que protege dados pessoais e privacidade de indivíduos na UE e EEE.
- 2) C — Informações de saúde protegidas (PHI).** HIPAA é legislação dos EUA que protege PHI (Protected Health Information) e estabelece padrões para segurança e privacidade de dados de saúde.
- 3) A — Saúde (US) / Financeiro (US) / Pessoais (UE).** HIPAA = saúde nos EUA; GLBA = dados financeiros nos EUA; GDPR = dados pessoais na União Europeia. São as leis de compliance que mais aparecem nas vagas de GRC.
- 4) A — Implementar a solução correspondente: Compliance: leis do setor + região (GDPR/P.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.4 (Compliance): Compliance: leis do setor + região (GDPR/PCI/HIPAA). As demais alternativas configuram violações graves de conformidade ou
- 5) D — Implementar a solução correspondente: Reputational damage costuma custar MAIS qu.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.4 (Compliance): Reputational damage costuma custar MAIS que a multa. As demais alternativas configuram violações graves de conformidade ou
- 6) D — Implementar a solução correspondente: 'protecting cardholder data'=PCI-DSS compl.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.4 (Compliance): 'protecting cardholder data'=PCI-DSS compliance. As demais alternativas configuram violações graves de conformidade ou fal
- 7) B — Implementar a solução correspondente: 'processadora de cartão precisa seguir'=PC.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.4 (Compliance): 'processadora de cartão precisa seguir'=PCI-DSS.. As demais alternativas configuram violações graves de conformidade ou fa
- 8) C — Implementar a solução correspondente: Compliance: leis do setor + região (GDPR/P.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.4 (Compliance): Compliance: leis do setor + região (GDPR/PCI/HIPAA). As demais alternativas configuram violações graves de conformidade ou
- 9) B — Implementar a solução correspondente: Reputational damage costuma custar MAIS qu.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.4 (Compliance): Reputational damage costuma custar MAIS que a multa. As demais alternativas configuram violações graves de conformidade ou
- 10) D — Implementar a solução correspondente: 'protecting cardholder data'=PCI-DSS compl.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.4 (Compliance): 'protecting cardholder data'=PCI-DSS compliance. As demais alternativas configuram violações graves de conformidade ou fal

